

Web VAPT Assessment — Final Report

README

This local lab demonstrates nine core web application vulnerability categories through controlled practice surfaces. The assessment workflow uses Burp Suite, OWASP ZAP, and Nmap concepts and requires evidence-backed remediation and retesting.

Methodology

Testing followed a scoped OWASP-based workflow: reconnaissance, baseline capture, authentication and session review, input validation, authorization testing, browser control testing, evidence capture, remediation, and retest. Findings use the lifecycle labels Open, Remediated, and Retested.

Reconnaissance

The authorized target is the local lab web server. The expected service is HTTP on port 3000. The endpoint map includes search, feedback, invoices, login, admin export, upload, profile email, diagnostic paths, and session lifecycle surfaces.

Vulnerability reports

ID	Vulnerability	Severity	Endpoint	Status
VAPT-01	SQL Injection	Critical	/api/products?search=	Open
VAPT-02	Cross-Site Scripting	High	/feedback	Open
VAPT-03	IDOR	High	/api/invoices/:id	Remediated
VAPT-04	Authentication weaknesses	High	/login	Open
VAPT-05	Broken access control	High	/admin/export	Remediated
VAPT-06	File upload vulnerabilities	Critical	/upload	Open
VAPT-07	CSRF	Medium	/profile/email	Retested
VAPT-08	Security misconfiguration	Medium	/.env / headers	Remediated
VAPT-09	Session-management issues	High	/session	Open

Every finding record includes vulnerability, severity, affected endpoint, reproduction steps, evidence location, business impact, remediation, and retest result in `vulnerability-reports/README.md`.

Remediation

The secure patterns are documented in `remediation/README.md`. They include parameterized queries, contextual output encoding, object ownership checks, strong authentication controls, deny-by-default authorization, safe file storage, CSRF tokens, hardened configuration, and secure session lifecycle controls.

Retest results

Retesting repeats the original reproduction steps against the secure path. CSRF has a passing retest record. IDOR, broken access control, and misconfiguration are marked Remediated and are awaiting or ready for repeat validation. The remaining findings are Open pending validation in the local lab workflow.

Resume bullet

Conducted a structured web application vulnerability assessment using Burp Suite, Nmap and OWASP-based testing methodologies; identified, documented and remediated security weaknesses with evidence and remediation recommendations.